

HW06 — Báo cáo API Testing trên EShop

- **Sinh viên:** Phạm Vũ Ngọc Duy — **MSSV:** 23127183
- **Môn:** Kiểm thử phần mềm — **Bài:** HW06-AI API Testing
- **SUT:** EShop — <https://github.com/ttbhanh/eshop-sut> · spec: `api_specification.md`
- **Repo:** <https://github.com/DuyPham111/HW06>

Số liệu trong báo cáo này copy từ [test-cases/test-summary/summary.md](#),
sinh tự động bằng `npm run summary` từ raw JSON của Newman.

Tóm tắt một trang

3 API (Pool A `POST /api/login`, Pool B `POST /api/apply-coupon`, Pool C `PUT /api/products/:id`) đã đi hết pipeline \$6.1–\$6.5: sinh **158 test case** (138 AI qua 5 bước riêng + 20 sinh viên tự thêm), audit qua 5 phép soát kết hợp chạy Newman thật, dựng 3 collection Postman + 1 regression suite (112 request). Chạy Newman thật cho **163 request/163 assertion, 47 đỏ**, quy đổi thành **27 bug đã tái hiện độc lập bằng cur1** (13 Critical). Bug nặng nhất — **PUT thiếu trường trên sản phẩm ID chẵn rồi GET lại làm sập toàn bộ backend** (BUG-19) — được phát hiện ngoài ý muốn trong lúc audit, không phải AI tự nghĩ ra. CI chạy thật trên GitHub Actions với 2 lượt mẫu có link thật: 1 lượt xanh hoàn toàn (regression 112/112) và 1 lượt đỏ (cổng bắt đúng hồi quy khi hạ baseline có chủ đích). Điều học được lớn nhất: AI đọc đúng logic tĩnh của code nhưng không mô phỏng được **thứ tự thực thi qua nhiều request** và **giá trị số cụ thể** — hai lỗi thiết kế test nghiêm trọng nhất của bài (mô hình khóa tài khoản sai, công thức coupon cho số âm) chỉ lộ ra khi chạy thật bằng `cur1`, không phải khi đọc bằng mắt.

Mục lục

1. Phạm vi và lý do chọn API
 2. Quy trình dùng AI từng bước
 3. API-01 — Pool A · `POST /api/login`
 4. API-02 — Pool B · `POST /api/apply-coupon`
 5. API-03 — Pool C · `PUT /api/productsid`
 6. Thực thi Postman + Newman
 7. Bug
 8. Postman feature đã dùng
 9. CI/CD
 10. AI test generator
 11. Human review — AI sai và bỏ sót gì
-

1. Phạm vi và lý do chọn API

§5 đòi 3 API, mỗi pool một API. Chi tiết + bằng chứng không trùng nhóm:
[docs/api-selection.md](#).

Mã	Pool	FR	API chính	Endpoint hỗ trợ	Prefix
API-01	A	FR-02	POST /api/login	POST /api/register , GET /api/users/me	TC-LOGIN-###
API-02	B	FR-09 (+FR-08, FR-10)	POST /api/apply-coupon	cart , checkout , coupon-usage , orders/:id , orders/:id/cancel , admin/orders/:id/status	TC-COUPON-###
API-03	C	FR-15	PUT /api/products/:id	POST / GET / DELETE /api/products/:id	TC-PRODUPD-###

Kế thừa đúng 3 FR đã chọn ở HW02/HW04/HW05 — giữ nguyên hướng khách hàng (storefront), không đổi sang admin back-office, để tận dụng hiểu biết đã có về nghiệp vụ và dùng bug đã biết từ HW02 làm chất liệu §6.3.

2. Quy trình dùng AI từng bước (§2, §6.1)

§2 cấm đích danh prompt gộp. Với **mỗi** API, test case được sinh qua **5 bước = 5 lượt riêng** (dạy AI về API → chốt bảng phân vùng → sinh Domain → sinh State/Security riêng → sinh Schema), thực hiện trực tiếp trong `generator/specs/<api>.mjs` và ghi log đầy đủ ở [ai-audit/ai-audit-report.md](#) (15 mục LOG).

Điểm khác biệt so với làm tay: trước khi sinh case, mỗi API đều được **dò hành vi thật bằng curl** (LOG-002/004/006) — đây là bước không nằm trong 5 bước lý thuyết nhưng bắt buộc trên thực tế, vì nó phát hiện được những sai lệch mà chỉ đọc code không thấy (vd: mô hình khóa tài khoản thật sự khác với suy luận từ đọc code, xem §11).

Nguyên tắc xuyên suốt: expected bám **đặc tả** (`api_specification.md` + FR/SEC), không bám hành vi hiện tại của code. SUT có bug cố ý, nên assertion đỏ là **phát hiện**, không phải lỗi test.

3. API-01 — Pool A • `POST /api/login`

3.0 Đặc tả và tham số

Tham số	Vị trí	Kiểu	Bắt buộc
<code>email</code>	body	string	có
<code>password</code>	body	string	có
(ẩn) trạng thái khóa	DB (<code>login_attempts</code> , <code>locked_until</code>)	—	FR-02: +1/lần sai, khóa từ lần 3, 30s

Chỗ đặc tả im lặng: định dạng email phía API (chỉ UI validate), trim khoảng trắng, giới hạn độ dài, hành vi khi body không phải JSON hợp lệ.

3.1–3.4 Phân bố test case

Kỹ thuật	Số case
Domain	18
State	12
Security	9
Schema	6
Tổng	45 (+6 SV)

3.5 Audit (§6.2)

40 VALID • 3 INVALID (đã sửa) • 2 chuỗi INCOMPLETE (thiếu bước `POST /api/register` trong chuỗi khóa tài khoản). Chi tiết đầy đủ + lý do từng lỗi: [test-cases/api-01-login/audit.md](#).

3.6 Case tự thêm (§6.3) — 6 case

DoS lockout hoàn chỉnh (2 request không cần biết mật khẩu), account enumeration qua so sánh 2 response, đăng ký trùng email, rò rỉ stack trace khi body lỗi, verify token dùng được xuyên-API. Chi tiết: [extended.md](#).

3.7 Kết quả và bug

Chỉ số	Giá trị
Request đã chạy	53
Assertion	53
Pass	44
Fail	9
Bug xác nhận	9 (BUG-01 → BUG-09)

Bug nặng nhất: **BUG-01** (Critical) — khóa được tài khoản người khác chỉ bằng email, không cần mật khẩu. Xem [bug-report/bug-report.md](#) §3.

4. API-02 — Pool B • `POST /api/apply-coupon`

4.0 Đặc tả và tham số

5 điều kiện FR-09 (C1 mã tồn tại · C2 còn hạn · C3 `total_amount >= min_order_amount` · C4 đã đăng nhập · C5 chưa hết lượt) + máy trạng thái FR-10 (`pending` → `confirmed` → `shipping` → `delivered` , `delivered` / `canceled` là trạng thái kết thúc).

4.1–4.4 Phân bố

Kỹ thuật	Số case
Domain	16
State	14
Security	11
Schema	7
Tổng	48 (+9 SV)

4.5 Audit

42 VALID · 1 INVALID (case AI_MISTAKE chép hành vi `>` của code thay vì `>=` của FR-09 C3) · 5 INCOMPLETE (2 case bị che khuất bởi trạng thái đơn từ bước trước, 1 chuỗi VIP100 thiếu 4/5 bước thật, 1 case reclassify từ "bug" thành "hành vi đúng" sau khi đối chiếu code). Chi tiết: [audit.md](#).

4.6 Case tự thêm — 9 case

Chuỗi price-tampering đầy đủ, chuỗi VIP100 5 bước thật (2 lần dùng + 2 lần ghi usage + 1 lần bị chặn), kiểm `NaN` trong công thức, hủy đơn 2 lần liên tiếp, case đối chứng hành vi đúng (ownership scoping). Chi tiết: [extended.md](#).

4.7 Kết quả và bug

Chỉ số	Giá trị
Request đã chạy	59
Assertion	59
Pass	46
Fail	13
Bug xác nhận	9 (BUG-10 → BUG-18)

Bug nặng nhất: **BUG-10** (Critical) — công thức phần trăm cho `discount_amount` **âm**, khách trả nhiều hơn giá gốc.

5. API-03 — Pool C • `PUT /api/products/:id`

5.0 Đặc tả và tham số

`name` (bắt buộc, ≤ 255 ký tự) • `price` (bắt buộc, > 0) • `category_id` (bắt buộc, tồn tại) • `description`, `imageUrl` (không giới hạn theo FR-15).

5.1–5.4 Phân bố

Kỹ thuật	Số case
Domain	16
State	10
Security	10
Schema	9
Tổng	45 (+5 SV)

5.5 Audit

39 VALID • 6 INCOMPLETE — trong đó **2 lần chính quá trình audit vô tình tái hiện bug crash server** (sản phẩm fixture tự tạo rơi vào ID chẵn; case DELETE dùng chung ID với case khác), đã sửa cả hai và ghi lại đầy đủ nguyên nhân. Chi tiết:

[audit.md](#).

5.6 Case tự thêm — 5 case

Payload crash server (không đưa vào collection chính, chỉ trong `verify-bugs.sh`), DELETE không cần token, đối chứng import-products (có auth) vs tạo sản phẩm đơn lẻ (không có auth), description rất dài, PUT body hoàn toàn rỗng (mức độ nặng nhất của lỗi mất dữ liệu). Chi tiết:

[extended.md](#).

5.7 Kết quả và bug

Chỉ số	Giá trị
Request đã chạy	51
Assertion	51
Pass	26
Fail	25
Bug xác nhận	9 (BUG-19 → BUG-27)

Bug nặng nhất trong **cả bài: BUG-19** (Critical) — `PUT` thiếu trường → `NULL` → `GET` trên sản phẩm ID chẵn gọi `null.toString()` → **sập toàn bộ tiến trình Node.js**, kèm stack trace thật đã lưu ở `bug-report/sut-crash-log.txt`.

6. Thực thi Postman + Newman (§6.4)

6.1 Môi trường

SUT	<code>http://localhost:3000</code> (Node.js/Express + SQLite), chạy cục bộ
Newman	6.2.2 + <code>newman-reporter-htmlextra</code>
Máy chạy	Windows 11, chạy qua Git Bash

6.2 Header `X-Student-Id` (§6.4, §11)

Đặt bằng **pre-request script cấp collection** ([postman/prerequest-collection.js](#)).

Bằng chứng: `bug-report/screenshots/postman-console-gui.png` — log Console + header + response 200.

6.3 Kết quả

Xem bảng đầy đủ ở [test-cases/test-summary/summary.md](#) —

163 request, 163 assertion, 116 pass, 47 fail trên cả 3 API.

6.4 Vì sao có nhiều assertion đỏ

Expected bám đặc tả, không bám hành vi SUT. SUT có bug cố ý → đỏ = phát hiện. Mỗi assertion đỏ map về đúng 1 trong 27 bug ở [bug-report/bug-report.md](#) §2 — bảng quy đổi đầy đủ, không có assertion đỏ nào không giải thích được.

7. Bug (§6.5)

Mức	Số bug
Critical	13
High	9
Medium	4
Low	1
Tổng	27

Chi tiết từng bug (đặc tả bị vi phạm, vị trí mã nguồn, bước tái hiện, kết quả thực tế) ở

[bug-report/bug-report.md](#) . Kèm 4 giả thuyết đã bị loại sau khi kiểm

chứng và 2 rủi ro chưa đủ căn cứ gọi là bug — ghi lại để không nhận vơ.

GitHub Issues: 27/27 đã tạo — <https://github.com/DuyPham111/HW06/issues> (#1–#27), mỗi issue gắn label mức độ + API, nội dung khớp `bug-report.md` , **23/27 đã đính ảnh bằng chứng**. Ảnh trang Issues và 2 issue tiêu biểu có trong [bug-report/bug-report.md](#) .

Số issue lệch số BUG ở khoảng giữa: `BUG-19` tạo trước nên nhận `#1` , đẩy `BUG-01 ... BUG-18` sang `#2 ... #19` ; từ `BUG-20` trở đi trùng số. Bảng quy đổi trong `bug-report.md` §2 ghi số thật.

8. Postman feature đã dùng (§6)

Xem bảng đầy đủ ở [postman/README.md](#). Đã dùng: Workspace, Collections (4), Folders theo kỹ thuật, Environment (16 biến), Variables (env + dynamic), pre-request script cấp collection, `pm.test` /JSON Schema, Postman Console, Newman CLI + htmlextra, Newman trong GitHub Actions, **Mock Server**, **Monitor**, và **chạy data-driven bằng file CSV**.

Data-driven chạy qua **Newman CLI** (`newman run ... -d postman/data/*.csv`) chứ không qua Collection Runner của Postman, vì tính năng nạp file dữ liệu trong GUI nay đã bị đưa vào gói trả phí. Kết quả kiểm thử là như nhau và không phải mua gì thêm.

9. CI/CD (§6)

Pipeline chạy SUT ngay trong job (checkout `ttbhanh/eshop-sut`), **hai bộ hai cổng**: regression suite (cổng 0 đỏ) + 3 collection bug-hunting (cổng so baseline), có **restart SUT giữa 2 bước** (xem lý do ở mục Sự cố cổ dưới). Chi tiết đầy đủ + 2 lượt mẫu **đã chạy thật** trên GitHub Actions: [ci/ci-report.md](#).

Lượt	Cổng	Kết quả	Link	Commit
XANH	<code>--strict</code> (regression) + baseline (bug-hunting)	112/112 pass, cả pipeline <code>success</code>	run #33649674605	72654a3
ĐỎ	baseline <code>api-01-login</code> hạ về 0 (demo)	bước "Cổng đỏ/xanh" → <code>failure</code> đúng thiết kế	run #33363180896	5d102c1

Sự cố CI thật đã gặp và tự sửa: một lượt CI ([run #33649322935](#))

từng đỏ ngoài dự kiến — `api-02-apply-coupon` báo 15 đỏ thay vì 13. Tải artifact bằng `gh run download` thì phát hiện nguyên nhân: coupon `VIP100` (2 lượt/người) bị **regression suite tiêu hết**

hạn mức trước, vì lúc đó pipeline chạy regression rồi bug-hunting trên **cùng một lần khởi động**

SUT. Đã sửa bằng cách thêm bước restart SUT giữa 2 bước — xem chi tiết đầy đủ ở

[ci/ci-report.md](#) §5. Đây là ví dụ thật của việc **đối chiếu số liệu CI với**

local bắt được lỗi mà chỉ chạy local sẽ không bao giờ thấy.

10. AI test generator (§7)

6 giai đoạn (parse 3 nguồn → suy ràng buộc → sinh 4 nhóm 4 lượt riêng → khử trùng/xếp thứ tự → xuất artefact → cổng kiểm chất lượng). **Đã hiện thực thật**: `tools/gen-artifacts.mjs` +

`tools/lib/postman-builder.mjs` đọc `generator/specs/*.mjs` sinh đồng thời bảng Markdown và collection Postman — đã dùng để sinh **toàn bộ 158 case + 4 collection** của bài này, không phải chỉ là thiết kế trên giấy. Chi tiết: [generator/design.md](#), pseudocode:

[generator/pseudocode.py](#).

Sơ đồ tự vẽ (\$11): đã vẽ tay trên draw.io ngày 31/08/2026 —

[generator/diagram/generator-flow-selfdrawn.png](#) ,

kèm file nguồn [.drawio](#) để chứng minh không phải ảnh do AI sinh.

Video demo (\$7, khuyến khích): <https://www.youtube.com/watch?v=l8-LSwX6y5s> — chạy skill `api-test-design` trực tiếp để sinh test case nhóm Domain cho `POST /api/login` , đúng yêu cầu "showing it generate tests for one API".

11. Human review — AI sai và bỏ sót gì

Log đầy đủ 15 mục ở [ai-audit/ai-audit-report.md](#) .
Bảng dưới đây tóm tắt 6 lỗi đáng chú ý nhất.

#	AI sai/bỏ sót gì	Ở đâu	Nhóm lý do	Đã sửa thế nào	Hậu quả nếu không phát hiện
1	Giả định khóa lộ ở response lần sai thứ 2 — thực tế lộ ở request thứ 3	API-01 state machine khóa	model limitations	Chạy <code>curl</code> 3 lần xác nhận đúng mô hình trước khi viết case	Case sẽ luôn PASS sai — không phát hiện được BUG-02
2	Dùng chung tài khoản <code>test@eshop.com</code> cho nhiều case "sai mật khẩu" độc lập	API-01 Domain folder	model limitations	Đổi sang tài khoản mới riêng (<code>Date.now()</code>) cho từng case	Hàng loạt case sau đổ vì môi trường, không phải vì bug
3	Chép công thức từ code (<code>></code>) rồi dán nhãn FR-09 lên	API-02 case biên <code>min_order_amount</code>	prompt quality (đọc code trước khi đọc kỹ FR)	Giữ nguyên case làm minh họa AI_MISTAKE, xác nhận đúng là BUG-08	Bỏ sót 1 bug thật (vi phạm C3)
4	Không tự thay số vào công thức coupon	API-02 công thức percent	model limitations	Tự tính tay + <code>curl</code> xác nhận: <code>discount_amount = -4.500.000</code>	Bug tài chính nghiêm trọng nhất bài bị bỏ sót
5	Sản phẩm fixture tự tạo rơi vào ID chẵn, dùng cho case "cập nhật một phần"	API-03 State folder	model limitations	Đổi sang sản phẩm <code>id=3</code> (lẻ, biết trước)	Sập toàn bộ SUT giữa lượt Newman, mọi case sau đổ vì môi trường
6	Case DELETE dùng chung <code>id=1</code> với case Schema khác đang cần	API-03 Security folder	model limitations	Đổi sang <code>id=4</code> (không dùng chung)	Case Schema sau đổ cho kết quả sai lệch (<code>price: undefined</code>)

Nguyên tắc chung rút ra (đầy đủ ở [ai-audit/ai-critique.md](#)):

AI đọc và tổng hợp logic tĩnh rất nhanh, nhưng không tự mô phỏng được **thứ tự thực thi qua nhiều request, trạng thái tích lũy**, hay **giá trị số cụ thể** — ba việc phải tự chạy thật bằng `curl` /Newman mới bù đắp được, không thể tin tưởng tuyệt đối vào suy luận đọc code.

Ai làm phần nào (§9 — AI Policy của bài là Open nên khai rõ):

Phần	Ai làm	Bằng chứng
Sinh test case (5 bước), dò hành vi thật bằng curl	AI (đóng vai theo yêu cầu người dùng), có giám sát	<code>ai-audit-report.md</code>
Phát hiện + sửa lỗi thiết kế test qua chạy Newman thật	AI, tự chạy và tự sửa	3 file <code>audit.md</code>
Chọn phạm vi case §6.3	AI đề xuất, người dùng có thể điều chỉnh	<code>extended.md</code>
Dựng collection Postman, chạy Newman, chạy CI	AI (dòng lệnh)	<code>postman/collections/</code> , <code>ci/ci-report.md</code>
Xác nhận/bổ sung ảnh Postman GUI, GitHub Issues, sơ đồ tự vẽ, video	người dùng	xem <code>docs/CAN-LAM-TIEP-THEO.md</code>